

Utilisations des sessions en PHP

Matisse Kra

bts sio

Table des matières

Table des matières	1
1. Objectif du TP	1
2. Environnement Technique	1
3. Architecture de l'application	1
4. Travaux réalisés et améliorations	1
5. Conclusion	2

1. Objectif du TP

L'objectif principal était de concevoir un système d'authentification rudimentaire permettant de restreindre l'accès à certaines pages d'un site web en utilisant le mécanisme des sessions PHP.

2. Environnement Technique

- Base de données : MySQL (nommée `monsite`) contenant une table `utilis` pour stocker les identifiants (nom, prénom, login, mot de passe).
- Langages utilisés : PHP pour la logique serveur, SQL pour la gestion des données, et HTML/CSS pour l'interface utilisateur.
- Sécurité : Utilisation de requêtes préparées (PDO) pour contrer les injections SQL et de la fonction `htmlspecialchars` pour prévenir les failles XSS.

3. Architecture de l'application

Le projet se compose de quatre fichiers principaux :

- `login.php` : Contient le formulaire de saisie du login et du mot de passe.

```
<!doctype html>    Add a new line at the end of this file.
<html>             Add "lang" and/or "xml:lang" attributes to this "<html
<head>
  <meta charset="UTF-8">
  <title>Connexion</title>
</head>
<body>
  <h1>Connexion utilisateur</h1>
  <form action="login_post.php" method="post">
    <label for="nom">Nom : </label>
    <input type="text" name="login" id="nom" required />

    <label for="mdp">Mot de passe : </label>
    <input type="password" name="mdp" id="mdp" required />

    <input type="submit" value="Connexion">
  </form>
</body>
</html>
```

- `login_post.php` : Traite les données du formulaire, interroge la base de données et initialise les variables de session (`$_SESSION`) en cas de succès.

```

<?php  Add a new line at the end of this file.
session_start();

if (isset($_POST['login']) && isset($_POST['mdp'])) {
    require 'fonctions.php';  Replace "require" with "require_once".
    $bdd = getBdd();

    $login = $_POST['login'];
    $mdp = $_POST['mdp'];

    // 1. On cherche d'abord si le login existe seul
    $reqLogin = 'SELECT * FROM utilis WHERE LoginUtil = ?';
    $resLogin = $bdd->prepare($reqLogin);
    $resLogin->execute(array($login));
    $utilisateur = $resLogin->fetch();

    if ($utilisateur) {
        // Le login existe, on vérifie maintenant le mot de passe
        if ($utilisateur['PassUtil'] == $mdp) {
            // Tout est bon
            $_SESSION['login'] = $login;
            $_SESSION['nom'] = $utilisateur['NomUtil'];
            $_SESSION['prenom'] = $utilisateur['PrenomUtil'];
            $authOK = true;
        } else {
            // Login trouvé mais mauvais mot de passe
            $erreur = 'Mot de passe incorrect.';
        }
    } else {
        // Le login n'existe pas dans la base
        $erreur = 'Login inconnu.';
    }
}
?>

```

- index.php : Page d'accueil dont l'affichage est personnalisé (ou l'accès restreint) selon que l'utilisateur est connecté ou non.

```

1  <?php  Add a new line at the end of this file.
2  session_start(); // INDISPENSABLE en haut du fichier
3  ?>
4  <!doctype html>
5  <html>  Add "lang" and/or "xml:lang" attributes to this "<html>" element
6  <head>
7      <meta charset="UTF-8" />
8      <title>Accueil du site</title>
9  </head>
10 <body>
11     <?php
12         // On vérifie si la session contient bien le prénom
13         if (isset($_SESSION['prenom'])) {
14             require 'fonctions.php'; // Pour utiliser la fonction escape
15             echo ' <h1>Bienvenue, ' . escape($_SESSION['prenom']) . ' </h1>';
16         } else {
17             echo ' <h1>Accueil du site</h1>';
18             echo ' <p>Identifiez-vous pour voir votre prénom.</p>';
19             echo ' <p><a href="login.php">Se connecter</a></p>';
20         }
21     ?>
22 </body>
23 </html>

```

- fonctions.php : Regroupe les fonctions utilitaires pour la connexion à la base de données (getBdd) et la sécurisation de l'affichage (escape).

```

<?php  Add a new line at the end of this file.
// fonctions.php

/**
 * Initialise la connexion à la base de données
 */
function getBdd()
{
    return new PDO('mysql:host=localhost;dbname=monsite;charset=utf8', 'monsite_util',
}

/**
 * Sécurise les données contre les injections XSS
 */
function escape($valeur)
{
    return htmlspecialchars($valeur, ENT_QUOTES, 'UTF-8', false);
}
?> Remove this closing tag ">".

```

4. Travaux réalisés et améliorations

Conformément aux consignes de l'activité, les améliorations suivantes ont été apportées:

1. Personnalisation de l'accueil : La page d'accueil affiche désormais le nom et le prénom de l'utilisateur (récupérés en base de données lors de la connexion) à la place du simple login.

Bienvenue, Gaspar

2. Gestion fine des erreurs : Le script de vérification a été modifié pour distinguer deux types d'échecs :
 - Le login saisi n'existe pas dans la base de données.

Résultat de l'authentification

Vous n'avez pas été reconnu(e)

Erreur : Login inconnu.

[Nouvel essai](#)

- Le login existe, mais le mot de passe associé est incorrect.

Résultat de l'authentification

Vous n'avez pas été reconnu(e)

Erreur : Mot de passe incorrect.

[Nouvel essai](#)

3. Persistance des données : L'utilisation de `session_start()` au début de chaque fichier permet de maintenir l'identité de l'utilisateur tout au long de sa navigation.

5. Conclusion

Ce TP a permis de comprendre l'importance des sessions pour sécuriser un espace utilisateur. Il a également mis en évidence la nécessité de séparer la logique de traitement (PHP/SQL) de l'affichage (HTML) pour garantir une application robuste et évolutive.